

BEFORE Placeholder

AFTER

Reporting Pack Guidance (Monthly / Quarterly) — Third-Party Security Program

Document classification: Internal

Document owner: Third-Party Security Program Owner

Version: 0.1

Effective date: _____

Review cadence: Annually

1. Purpose

This guidance defines how to compile consistent reporting packs for operational and senior stakeholders, using the program's KPI/KRI set and standard templates.

2. Reporting principles

- Keep reporting **decision-oriented**: each pack must drive actions, approvals, or prioritisation.
- Report by **tier** (Critical / Important / Low) and highlight Critical suppliers explicitly.
- Prefer **trends** and **exceptions** over raw volume.
- Use **RAG** status with clear thresholds (e.g., any expired exception = Red).
- Ensure metrics are supported by **verifiable registers** (intake, gaps, exceptions, incidents).

3. Pack types and audiences

3.1 Weekly Operational Scoreboard (TPSR)

Audience: TPSR stakeholders (Security, Procurement, IT/Platform, BSO)

Objective: manage flow, clear blockers, keep SLAs healthy.

Template: ``metrics/03-weekly-operational-scoreboard.md``

Include:

- pipeline counts (in/out/WIP)
- ageing/SLA health + top delay reasons
- top 5 blockers with owners and dates
- exceptions expiring in 30 days
- decisions required this week

Avoid:

- long narrative; keep to "what's stuck and who owns it".

3.2 Monthly Management Dashboard

Audience: Senior Technology/Security leadership, Technology Risk (as applicable)

Objective: visibility into Critical supplier posture, exceptions, material gaps, incidents, and program performance.

Template: ``metrics/02-monthly-dashboard-template.md``

Minimum sections:

- Executive summary + RAG
- Supplier population snapshot and changes
- KPI section (flow and adoption): coverage, lead time, conditional closure, onboarding pattern adoption, offboarding completeness
- KRI section (risk posture): assessment currency, high-severity gaps, exceptions ageing/expiry, privileged access/connectivity exposure, logging gaps, sub-processor gaps, incidents
- Top 5 Critical supplier attention list
- Decisions required (residual risk acceptance, renewal blockers, offboarding recommendations)
- Next-month plan (3 bullets)

3.3 Quarterly Senior Pack (Exec/Board-facing, generic)

Audience: Senior governance stakeholders (generic)

Objective: strategic risk posture and progress, not operational backlog.

Format: 2–6 pages, minimal detail.

Minimum content:

- Headline risk posture (RAG) and trend
- Critical supplier coverage and assessment currency trend
- Exceptions profile (count, ageing, expired = 0 target) and key themes
- Concentration risk summary (single points of failure) and mitigation status
- Third-party incidents summary and notification performance
- Material decisions and residual risk accepted in period (by generic role)
- Key program improvements delivered and next-quarter priorities

Avoid:

- vendor-by-vendor detail unless a material risk requires it.

4. Standard RAG rules (recommended)

- Red:
 - any expired exception
 - any past-due high-severity gap on a Critical supplier
 - any Critical supplier out of assessment currency threshold
 - any Critical supplier lacking required logging/auditability without exception
- Amber:
 - worsening trend in exception ageing or lead time
 - repeated conditional actions overdue (Important)
 - rising privileged access/connectivity exposure without reduction plan
- Green:

- thresholds met and trend stable/improving

5. Data sources and traceability

Each pack MUST reference its source registers:

- Intake Register (new/triaged/backlog)
- Assessment Register (decisions, lead time)
- Gap/Remediation Register (conditions, overdue items)
- Exception Register (volume, ageing, expiry)
- Critical Supplier Inventory (currency)
- Incident Records (supplier incidents and notification performance)
- Offboarding Records (completeness)

Rule: if a number can't be traced back to a register, don't report it.

6. Suggested charts/tables (optional)

Monthly:

- Trend (3–6 months): due diligence lead time (median)
- Trend: active exceptions (count) and median ageing
- Snapshot table: top 5 Critical suppliers needing attention

Quarterly:

- Trend: Critical assessment currency
- Trend: incidents and notification performance
- Concentration risk table (critical services with single supplier dependency)

7. Decision hygiene (what to include for each decision)

For any decision request in a pack, include:

- Supplier (synthetic name acceptable)
- Tier
- Decision required (approve exception / renew / restrict scope / offboard plan)
- Summary of gap and compensating controls
- Residual risk statement (plain language)
- Owner and due date
- Approval authority required (generic role titles)

8. Distribution and confidentiality

- Packs containing supplier assurance artifacts (e.g., SOC reports) must be distributed on a need-to-know basis.
- Use synthetic supplier names if a pack will be shared outside the organisation (e.g., as a portfolio artifact).

9. Version control

- Store each final monthly and quarterly pack in the approved repository/location with:
 - reporting period,
 - prepared-by role title,
 - version,
 - link to source registers used.